

Systematic Mapping of the literature on Secure Software Development

O artigo apresenta um estudo de mapeamento sistemático de literatura sobre segurança no desenvolvimento de software, analisando artigos relevantes publicados entre 2014 e 2019. O objetivo principal é fornecer um panorama das tendências atuais e identificar as lacunas de pesquisa nessa área, motivado pelo fato de que mais de 90% dos ciberataques exploram vulnerabilidades geradas durante o próprio processo de desenvolvimento.

Os estudos revelam que a fase de construção de código seguro (codificação) é a mais estudada, concentrando 42% das pesquisas, seguida pelas fases de design (24%), requisitos (20%) e testes de segurança (14%). Dentro de cada uma dessas etapas de engenharia de software o estudo mapeou as seguintes práticas predominantes:

- Requisitos de segurança: As subfases de elicitação e análise de requisitos são as mais frequentes, destacando-se o uso de técnica Misuse Case (Casos de Mau Uso) para identificar ameaças potenciais.

- Design de segurança: As principais tendências envolvem a segurança em sistemas baseados em componentes (lidando com riscos herdados de terceiros ou código aberto), a modelagem de ameaças (Threat Modeling) e o uso de padrões de segurança (Security Patterns) reutilizáveis.

- Construção de Código: A técnica de análise estática de código é o tópico mais recorrente (25%) para mitigar falhas. No âmbito das vulnerabilidades, o foco está na detecção e prevenção de explorações, apoiando-se fortemente em bases de dados públicas.

- Testes de segurança: Os métodos predominantes e mais consolidados na literatura são a varredura de vulnerabilidades e os testes de invasão.

Em termos globais, o levantamento indica um crescimento acentuado na aplicação de técnicas de Inteligência Artificial, com o aprendizado de máquina liderando as abordagens tecnológicas para automatizar a segurança. Por outro lado, o artigo aponta um gargalo humano crítico no setor: a maior dificuldade enfrentada pela indústria é a necessidade de assistência e treinamento para os desenvolvedores. Os profissionais frequentemente carecem de competências específicas, necessitam do suporte de especialistas e sentem-se sobrecarregados com as exigências de segurança, o que reforça a urgência de mudar a mentalidade e integrar a segurança desde a concepção do ciclo de vida do software, em vez de aplicar correções tardias na fase de produção.

Além disso, a falta de padrões e frameworks claros para a integração de segurança no ciclo de vida do desenvolvimento de software é apontada como uma das principais barreiras. A adoção de práticas como o DevSecOps é vista como uma solução promissora para superar esses desafios, permitindo a integração contínua de segurança em todas as etapas do desenvolvimento. No entanto, a implementação do DevSecOps requer mudanças significativas na cultura organizacional e na forma como o trabalho é realizado, o que pode ser um desafio para algumas organizações.

Concluindo, a segurança no desenvolvimento de software é um tema complexo e em constante evolução. Embora existam avanços tecnológicos e metodológicos, a maior barreira continua sendo humana. Investimentos em treinamento, conscientização e a adoção de práticas como o DevSecOps são essenciais para garantir a segurança dos sistemas de software em um cenário cada vez mais ameaçado.